

Glosario

Glosario

Módulo 1: Datos y privacidad.....	2
Módulo 2: Gobernanza, riesgo y cumplimiento.....	8
Módulo 3: Amenazas y vulnerabilidades.....	12
Módulo 4: Gestión de vulnerabilidades.....	15
Módulo 5: Seguridad del sistema.....	18
Módulo 6: Seguridad de la red.....	23
Módulo 7: Computación en la nube y virtualización.....	29
Módulo 8: Protección de la infraestructura en la nube.....	32
Módulo 9: Operaciones de seguridad.....	36
Módulo 10: Supervisión de la seguridad.....	39
Módulo 11: Respuesta a incidentes.....	42
Módulo 12: Análisis forense de sistemas digitales.....	44
Módulo 13: Amenazas emergentes y futuro de las tecnologías de ciberseguridad.....	48

Glosario

Módulo 1: Datos y privacidad

Término	Definición
Controles administrativos	Pautas, políticas y procedimientos escritos para cumplir y aplicar los objetivos de seguridad.
Software antimalware (antivirus)	Software que detecta, pone en cuarentena y destruye malware que amenaza datos o redes.
Cifrado asimétrico	Un proceso de cifrado que implica el uso de dos claves: una clave pública para cifrar datos y una clave privada para descifrarlos.
Disponibilidad	Un objetivo de la tríada CIA es garantizar el acceso oportuno y confiable a los datos y su uso.
Autenticación	Una medida para verificar la fuente de un mensaje.
Cifrado A1Z26	Un proceso de cifrado que reemplaza cada letra de texto sin formato con un número correspondiente al orden de esa letra en el alfabeto
Software de copia de seguridad	Software que crea copias adicionales de datos que se pueden usar para recuperar datos críticos perdidos debido a filtraciones, fallas del sistema u otros eventos de seguridad.
Ataque de fuerza bruta	Un ciberataque en el que el atacante prueba diferentes contraseñas hasta que encuentra una que funcione.
Cifrado César	Un proceso de cifrado que reemplaza cada letra del texto sin formato con la letra tres lugares antes o después en el alfabeto.
La tríada CIA	Un modelo de seguridad de la información con confidencialidad, integridad y disponibilidad como objetivos de protección de datos.
Cifrado	Un conjunto de transformaciones que convierten texto sin formato, los datos inteligibles y legibles por humanos, en texto cifrado, la forma cifrada de los datos.
DLP en la nube	Un tipo de prevención de pérdida de datos que implica detectar y cifrar datos confidenciales antes de almacenarlos en la nube.
Datos confidenciales	Datos que una organización protege del acceso no autorizado, como información patentada, código fuente, registros de empleados, información de identificación personal (PII) e información de salud protegida (PHI).
Confidencialidad	Objetivo de la tríada CIA que consiste en proteger los datos garantizando que solo las personas autorizadas puedan acceder a ellos o divulgarlos.
Control	Una medida que puedes tomar para mitigar los riesgos. Los controles son de tres tipos: administrativos, físicos y técnicos.

Glosario

Término	Definición
Ciberatacante (atacante)	Un hacker que intenta eludir la seguridad del sistema o de la red para acceder a los datos sin autorización con fines maliciosos.
Datos en reposo	Datos que residen en un dispositivo de almacenamiento.
Software de borrado de datos	Software que borra permanentemente los datos innecesarios o no utilizados de un repositorio.
Datos en movimiento (datos en tránsito)	Datos que se mueven activamente a través de una red o entre sistemas.
Datos en uso	Datos que una computadora o aplicación utiliza y procesa activamente.
Sistemas de prevención de pérdida de datos (DLP)	Procesos, procedimientos y herramientas que ayudan a detectar y prevenir la pérdida de datos.
Privacidad de datos	La seguridad de los datos se centraba únicamente en impedir la recopilación, divulgación o uso no autorizados de los datos privados de clientes y empleados.
Data security	Cómo una organización protege los datos confidenciales del acceso no autorizado, la divulgación o la destrucción.
Copias de seguridad diferenciales	Un proceso de copia de seguridad de datos que comienza con una copia de seguridad completa y luego cada copia de seguridad adicional incluye solo los cambios realizados desde la última copia de seguridad completa.
Cifrado	Control técnico que garantiza la confidencialidad de los datos convirtiendo los datos legibles en un formato ilegible.
Software de cifrado	Software que convierte los datos a un formato que las personas no autorizadas no pueden entender, preservando la confidencialidad.
DLP de endpoint	Un sistema que monitorea todos los endpoints para detectar pérdidas o fugas de datos.
Cifrado de archivos	El proceso de cifrar archivos o sistemas de archivos para que solo aquellos con la clave puedan acceder a ellos.

Glosario

Término	Definición
DLP a nivel de archivo	Un sistema que identifica archivos confidenciales en un sistema de archivos.
Copias de seguridad completas	Un proceso de copia de seguridad de datos en el que copias todo el contenido de tu sistema o dispositivo.
Cifrado de unidad completa	El proceso de cifrar un disco duro completo, incluidos sus datos, archivos, programas y sistema operativo.
Principios de privacidad generalmente aceptados (GAPP)	Un estándar para la privacidad de datos desarrollado por el American Institute of Certified Public Accountants (AICPA) y el Canadian Institute of Chartered Accountants (CICA).
Hacker	Alguien que intenta burlar la seguridad del sistema o de la red para acceder a los datos.
Cifrado del disco duro	El proceso de cifrado de datos almacenados en un disco duro y la incorporación de nuevos archivos.
Copias de seguridad incrementales	Un proceso de copia de seguridad de datos que captura solo los cambios realizados desde la última copia de seguridad.
Integridad	Un objetivo de la tríada CIA que significa proteger los datos de la modificación y destrucción no autorizadas para garantizar que sean confiables y precisos.
Malware	Software o firmware destinado a realizar acciones no autorizadas que afectan negativamente la seguridad del sistema.
Cifrado monoalfabético	Un proceso de cifrado que reemplaza cada letra de texto sin formato por otra letra en el alfabeto. Por ejemplo, tal vez todas las <i>A</i> se conviertan en <i>Z</i> y todas las <i>B</i> se conviertan en <i>Y</i> .
DLP de red	Un sistema que protege los datos en reposo, en movimiento o en uso en la red de una organización.
Cifrado de red	Cifrado para proteger datos confidenciales en movimiento entre el servidor y el cliente.
No repudio	Garantía de que ni el emisor ni el receptor de un mensaje pueden negar su transmisión; el emisor recibe una prueba de entrega y el

Glosario

Término	Definición
	receptor recibe una prueba de la identidad del emisor.
Información de identificación personal (PII)	Datos privados que se pueden utilizar para identificar a alguien, como cumpleaños, direcciones, números de teléfono y números de identificación emitidos por el gobierno.
Controles físicos	Dispositivos o estructuras diseñados para restringir el acceso a áreas o dispositivos que contienen datos confidenciales. Algunos ejemplos comunes son las vallas, las cerraduras, las tarjetas de acceso, las cámaras de seguridad, las alarmas y los gabinetes.
Datos privados	Datos sobre una persona y su vida privada que otras partes no deberían poder recopilar, usar o divulgar a menos que se autorice. Algunos ejemplos incluyen actividad financiera, números de tarjetas de crédito, credenciales de inicio de sesión de correo electrónico, información de identificación personal (PII) e información de salud protegida (PHI).
Datos propios	Datos propiedad de la organización o generados por la organización relevantes para los productos o acciones de la organización que deben permanecer confidenciales.
Información de salud protegida (PHI)	Datos privados de los historiales médicos utilizados para identificar a alguien, como diagnósticos, resultados de pruebas, recetas e información del seguro médico.
Datos públicos	Datos a los que cualquiera puede acceder, así como usar y redistribuir sin restricciones.
Cifrado simétrico	Un proceso de cifrado que implica el uso de una única clave privada para cifrar y descifrar datos.
Controles técnicos	Hardware o software que ayuda a proteger datos o procesos. Los ejemplos más comunes incluyen software antimalware y software de cifrado.
Amenaza	Algo que puede causar daño a una red, sistema o datos.
Vulnerabilidad	Una debilidad en hardware, firmware o software que un hacker puede explotar.

Glosario

Preguntas que tengo

Ejemplo: ¿Cuál es la diferencia entre datos confidenciales y datos privados?

Glosario

Mis notas

Ejemplo: Los datos confidenciales son datos que una organización protege del acceso no autorizado, como la información propietaria, el código fuente, los registros de empleados, la información personal identificable (PII) y la información de salud protegida (PHI).

Los datos privados son un **tipo** de datos confidenciales. En concreto, se trata de datos confidenciales sobre una **persona**, como credenciales de inicio de sesión, números de tarjetas de crédito y resultados de pruebas médicas.

Glosario

Módulo 2: Gobernanza, riesgo y cumplimiento

Término	Definición
California Consumer Privacy Act (CCPA)	Una ley de privacidad de datos que se aplica a cualquier organización que haga negocios en California y deba compartir con los clientes los datos que recopila sobre ellos y sus hijos.
Controles de cumplimiento	Controles basados en el riesgo que las empresas implementan para proteger la confidencialidad, la integridad y la disponibilidad de los datos y cumplir con las leyes, reglamentos y estándares.
Compliance (en ciberseguridad)	El cumplimiento de una organización de las leyes, regulaciones y estándares aplicables diseñados para mantener los datos y los sistemas a salvo de las amenazas cibernéticas.
Plan de preparación ante desastres	Un plan escrito que enumera las precauciones que toma una organización para prevenir o mitigar el daño que causan los desastres.
Plan de recuperación en caso de desastre (DRP)	Un plan escrito para recuperar datos o sistemas si ocurre un desastre.
Federal Educational Rights and Privacy Act (FERPA)	Ley federal estadounidense destinada a mantener la privacidad de los expedientes académicos de los alumnos. La ley exige que las escuelas apliquen controles adecuados, como políticas, procedimientos y capacitación, para impedir el acceso, la divulgación y el uso no autorizados de esos registros.
Reglamento General de Protección de Datos (RGPD)	Una extensa ley y regulación sobre privacidad de datos que se aplica a cualquier empresa que aloje datos de residentes de la UE o haga negocios con países de la UE.
Ley Gramm-Leach-Bliley (GLBA)	Una ley federal de EE. UU. que exige que las instituciones financieras y las empresas que ofrecen productos o servicios financieros a los consumidores estadounidenses divulguen sus prácticas de intercambio de datos a los clientes.
Gobernanza	El proceso de tomar y hacer cumplir decisiones dentro de una organización. Define cómo un órgano rector estructura y sustenta las reglas, normas y acciones, y cómo responsabiliza a todos por ellas.
Gobernanza, riesgo y cumplimiento (GRC)	Una forma estructurada de alinear los objetivos comerciales de una organización con su reconocimiento del riesgo y la mitigación de riesgos para cumplir con todas las regulaciones y estándares gubernamentales y de la industria.

Glosario

Término	Definición
Directriz	Una forma recomendada, no obligatoria, de realizar una tarea en una organización. Por ejemplo, una directriz de la empresa puede ser que los empleados utilicen una plantilla específica de PowerPoint para todas las reuniones internas. Pero si un empleado infringe esta directriz, probablemente recibirá un recordatorio, no un castigo.
Ley de Portabilidad y Responsabilidad del Seguro Médico (HIPAA)	Una ley federal de EE. UU. que define el control de la información de salud protegida (PHI), como registros médicos y diagnósticos. La Regla de privacidad de la HIPAA impone restricciones estrictas sobre el acceso y la divulgación de la PHI de una persona. La Regla de seguridad de la HIPAA establece estándares para proteger la PHI.
Estándares de redes IEEE 802	Orientación estándar de la industria para proteger redes de área de varios tamaños. Por ejemplo, los estándares cubren el acceso a la red, el cifrado y la detección de amenazas.
ISO 2700 e ISO 27001	Normas internacionales para una amplia gama de temas de ciberseguridad, como la evaluación de riesgos, la creación de sistemas de gestión de la seguridad de la información y el despliegue de controles de seguridad.
Ley	Un requisito legal establecido por un congreso, parlamento u otro grupo legislativo. Las leyes suelen ser de amplio alcance. Violarlas puede dar lugar a sanciones, multas y otras consecuencias legales. En el contexto de la ciberseguridad, las leyes protegen los datos y castigan a quienes violan su confidencialidad, integridad o disponibilidad sin la debida autorización.
Riesgos multiparte	Riesgos que afectan a más de una organización. Un ejemplo común es una interrupción de Internet o de un proveedor de servicios.
National Institute of Standards and Technology (NIST)	Una agencia federal de EE. UU. dedicada a promover la tecnología y la innovación locales que proporciona amplios recursos de ciberseguridad, incluidos cientos de estándares de ciberseguridad y privacidad de datos.
Marco de gestión de riesgos (RMF) del NIST	Un enfoque integral, repetible y medible para gestionar la seguridad de los datos y los riesgos de privacidad. Incluye siete pasos.
Normativa de ciberseguridad del NYDFS	Una regulación del estado de Nueva York que requiere que las instituciones financieras que hacen negocios en el estado realicen gestión de riesgos.
Payment Card	Un estándar de seguridad de datos para tarjetas de crédito que se

Glosario

Término	Definición
Industry Data Security Standard (PCI DSS)	aplica a organizaciones que almacenan o transmiten datos de tarjetas de crédito.
Procedimiento	Procesos paso a paso para completar una tarea con el fin de cumplir una norma o directriz.
Política	Una declaración amplia sobre la intención general de una organización y cómo debe ejecutarse, incluyendo detalles sobre los objetivos, intenciones y valores de la organización que la organización debe defender con el marco de seguridad.
Regulación	Un requisito legal, establecido por un organismo gubernamental, destinado a interpretar y aplicar una ley. Los reglamentos aclaran lo que deben hacer las organizaciones para cumplir la ley. El incumplimiento de la normativa puede acarrear sanciones, multas y otras consecuencias legales.
Riesgo	El grado en que un posible ataque cibernético u otro evento amenaza las operaciones de una organización.
Evaluación de riesgos	Un proceso de identificación de riesgos, evaluación de su impacto y decisión de qué hacer al respecto.
Gestión de riesgos	Proceso de identificación, evaluación y control de riesgos financieros, legales, estratégicos y de seguridad para el capital y las ganancias de una organización.
Tolerancia al riesgo	Nivel de riesgo o grado de incertidumbre que es aceptable para las organizaciones.
Estándar (en cumplimiento)	Un conjunto de pautas o mejores prácticas creadas por expertos, grupos de la industria o gobiernos que las organizaciones pueden seguir.
Estándar (en gobernanza)	Un requisito medible que todos los empleados de una organización deben seguir. Los ejemplos comunes incluyen ajustes de configuración para dispositivos o requisitos para usar equipos de la empresa.

Preguntas que tengo

Glosario

Glosario

Mis notas

Glosario

Módulo 3: Amenazas y vulnerabilidades

Término	Definición
Adware	Software publicitario que muestra automáticamente anuncios no solicitados en un dispositivo.
Bot (definición estándar)	Un programa que realiza tareas automatizadas a través de una red. Un ejemplo común es un chatbot que realiza atención al cliente.
Bot (específicamente, un bot malicioso o un zombi)	Un dispositivo conectado a Internet infectado con malware que permite al atacante controlar el dispositivo de forma remota. A menudo, se le denomina bot en ciberseguridad.
Botnet	Una red de bots maliciosos que un atacante controla bajo la misma instancia para lanzar ciberataques.
Defensa en profundidad	Una estrategia en la que se emplean varias capas de controles de seguridad para proteger los activos. Por ejemplo, es posible que un empleado tenga que pasar controles físicos, como un guardia y cámaras de seguridad, antes de ingresar con éxito sus credenciales de inicio de sesión, un control técnico.
Sistemas de control de acceso a puertas	Sistemas que restringen la entrada solo a quienes tienen las credenciales correctas.
Dumpster diving	Cuando alguien busca información confidencial en la papelera de una persona o empresa.
Interferencia electromagnética (EMI)	Interferencia causada por la radiación electromagnética que puede obstaculizar el rendimiento del hardware. Generalmente, la EMI proviene de dispositivos electrónicos, como computadoras, teléfonos celulares, microondas y luces LED.
Blindaje EMI	Una técnica que encierra equipos, como audio-video (AV) y cables Ethernet, dentro de materiales conductores o magnéticos para bloquear ondas electromagnéticas externas.
Keylogger	Spyware que registra cada pulsación de tecla que realizas en tu dispositivo.
Bomba lógica	Malware guardado en un archivo o incrustado en software que se activa solo cuando se cumplen condiciones específicas, como una hora específica del día.
Malware	Software diseñado para amenazar la confidencialidad, integridad o disponibilidad de datos o sistemas.
Malwarebytes	Un programa antimalware que detecta y elimina malware, como virus, exploits y ransomware.
Firma de	Un patrón de atributos que corresponde al malware conocido.

Glosario

Término	Definición
malware	Cuando el software antimalware identifica una firma en un archivo, el software elimina el archivo, lo pone en cuarentena o te avisa de que el archivo podría estar infectado.
Gestión de parches	Proceso de actualización del software para agregar nuevas funciones o corregir vulnerabilidades.
Phishing	La práctica de enviar mensajes, aparentemente de una organización legítima, para engañar a los usuarios para que proporcionen información confidencial.
Amenaza física	Una amenaza directa a los activos, como la intrusión no autorizada en un área restringida y los peligros naturales, como los incendios.
Shoulder surfing	Cuando un atacante roba tu información personal al mirar por encima de tu hombro mientras usas una computadora o un dispositivo.
Ingeniería social	El uso del engaño para hacer que las personas divulguen información confidencial o privada con fines fraudulentos.
Spear phishing	Un tipo de phishing dirigido a una persona, grupo u organización específica.
Tailgating	Cuando una persona no autorizada ingresa a un área restringida siguiendo a una persona autorizada.
Ransomware	Malware que toma tu sistema como rehén, lo infecta, restringe el acceso a él o a sus datos y te solicita que pagues un rescate para recuperar el acceso.
Spyware	Malware instalado en secreto en un dispositivo o sistema para recopilar y notificar datos, como pulsaciones de teclas, hábitos de navegación web, historial de descargas y otros comportamientos en Internet.
Troyano	Un programa aparentemente útil diseñado para dar a un atacante acceso a un dispositivo en secreto para controlarlo de forma remota, robar datos, espiar la actividad, instalar malware o realizar otras acciones maliciosas.
Virus	Malware que se adjunta a los archivos o programas de un dispositivo para replicarse y luego se propaga a otro dispositivo.
Gusanos	Malware que se autorreplica sin necesidad de los archivos o programas de un dispositivo host y luego se propaga a través de los sistemas.
Vulnerabilidad de día cero	Una falla de seguridad previamente desconocida en el software que no fue solucionada.

Glosario

Preguntas que tengo

Mis notas

Glosario

Módulo 4: Gestión de vulnerabilidades

Término	Definición
Cross-site scripting (XSS)	Un ataque que inserta código malicioso en la página web de un cliente. Cuando un usuario accede a la página, su navegador reconoce el código como proveniente de un sitio confiable, lo que permite que el código se ejecute.
Atacante cibernético	Alguien que intenta eludir la seguridad del sistema o de la red sin autorización con fines maliciosos.
Hacker ético o investigador de seguridad ofensiva	Un hacker que trabaja con organizaciones para identificar y corregir vulnerabilidades, no explotarlas con fines maliciosos.
Marcos de explotación	Herramientas que proporcionan repositorios de ataques cibernéticos y exploits prediseñados. Por ejemplo, con la aplicación Metasploit, puedes buscar ataques adaptados a una versión específica de un sistema operativo al que deseas dirigirte y luego dejar que Metasploit realice el ataque.
Expresión	Combinación de componentes de código que un programa puede interpretar y emplear.
Footprinting o reconocimiento	El acto de perfilar un sistema y sus usuarios para recopilar inteligencia de amenazas. Por ejemplo, un evaluador de pruebas de penetración podría recopilar las direcciones IP y los nombres de dominio de una red y determinar su topología.
Host	Un dispositivo, como un servidor o una computadora portátil, que puede comunicarse con otros dispositivos en una red y otorgar acceso a dispositivos fuera de la red.
Indicadores de compromiso (IOC)	Los síntomas o evidencias de un ciberataque. Por ejemplo, el asunto de un correo electrónico sospechoso puede coincidir con el de una estafa de phishing conocida.
Inteligencia	Información y conocimiento sobre un adversario obtenidos a través de la observación, la investigación, el análisis o la comprensión.
JavaScript Object Notation (JSON)	Formato de datos estándar basado en texto legible por el ser humano que puede almacenar y transmitir fácilmente mediante un sistema automatizado.
Mapeadores de red	Herramientas para encontrar y mapear todos los dispositivos de una red y descubrir datos sobre cada dispositivo, como su dirección IP.
Puerto abierto	Un puerto de red que acepta una conexión. Los atacantes quieren encontrar y explotar puertos abiertos, mientras que los administradores de red quieren cerrarlos o bloquearlos, a la vez

Glosario

Término	Definición
	que se aseguran de que los usuarios legítimos sigan teniendo acceso.
Open-source intelligence (OSINT)	Inteligencia que cualquiera puede crear a partir de información disponible públicamente. Las fuentes habituales de OSINT incluyen blogs, bibliotecas, organizaciones de noticias, sitios web de empresas, redes sociales y registros públicos.
Inteligencia operacional	Inteligencia que ayuda a los equipos de seguridad a anticipar y prevenir ataques futuros.
OWASP ZAP	Un escáner de vulnerabilidades gratis de código abierto y una herramienta de pruebas de penetración diseñada para probar la seguridad de una aplicación web.
Analizador de paquetes	Una herramienta que captura e inspecciona datos en tránsito a través de una red.
Pruebas de penetración	Un tipo de prueba de seguridad que simula técnicas reales de hacking para encontrar vulnerabilidades de aplicaciones, redes o sistemas que los atacantes pueden explotar.
Escáner de puertos	Un programa que identifica los puertos abiertos o disponibles de una red.
Araña o rastreador web	Un programa que busca e indexa contenido web.
Inteligencia estratégica	Inteligencia de alto nivel sobre las tendencias mundiales actuales en ciberamenazas.
Structured Threat Information Expression (STIX)	Un lenguaje de programación de código abierto que proporciona un formato estandarizado para compartir inteligencia de amenazas.
Inyección SQL	Un ciberataque que coloca código malicioso en una sentencia de lenguaje de consulta estructurado (SQL) a través de una aplicación o sitio web. Los atacantes normalmente emplean una solicitud de entrada del usuario, como un nombre de usuario, para ingresar la sentencia SQL, que se ejecuta en la base de datos del servidor.
Inteligencia táctica	Inteligencia que ayuda a los equipos de seguridad a detectar los ciberataques y responder a ellos en tiempo real.
Actor de amenazas (actor malicioso)	Una entidad, como una persona, grupo u organización, que representa una amenaza de ciberseguridad.
Inteligencia de amenazas	Inteligencia que ayuda a las organizaciones a tomar decisiones informadas sobre las amenazas de ciberseguridad.
Evaluación de	Un proceso sistemático en el que identificas y evalúas

Glosario

Término	Definición
vulnerabilidades	vulnerabilidades de sistemas, redes o aplicaciones para determinar el riesgo de seguridad.
Escaneo de vulnerabilidades	Una evaluación asistida por software de un sistema para detectar vulnerabilidades conocidas.
Escáner de vulnerabilidades	Una aplicación que analiza un sistema en busca de vulnerabilidades conocidas.

Preguntas que tengo**Mis notas**

Glosario

Glosario

Módulo 5: Seguridad del sistema

Término	Definición
Servidor de aplicaciones	Un servidor que conecta a los clientes con aplicaciones de software mediante conexiones de servidor virtual.
Bootkit	Malware que infecta el cargador de arranque de una computadora o el registro de arranque maestro (MBR), que es responsable de iniciar el sistema operativo.
Programa de arranque	Software que carga el sistema operativo en la computadora, permitiendo que las aplicaciones interactúen con su hardware.
Cliente	Un dispositivo conectado a una red.
Servidor de colaboración	Un servidor que permite a varios usuarios compartir y almacenar archivos, aplicaciones y grandes cantidades de datos.
Common Weakness Enumeration (CWE)	Una lista desarrollada por la comunidad de puntos débiles del software que pueden dar lugar a vulnerabilidades de seguridad en el firmware.
Servidor de base de datos	Un servidor que funciona como un gran espacio de almacenamiento que la organización utiliza y al que accede para ejecutar múltiples programas.
Servidor de sistema de nombres de dominio (DNS)	Un servidor que transforma nombres de dominio de computadora legibles en direcciones de protocolo de Internet (IP) en lenguaje de computadora, tomando datos de búsqueda de un usuario para encontrar la dirección solicitada para enviarla a otro dispositivo.
Servidor de archivos	Un servidor que almacena archivos de datos para múltiples usuarios y permite una recuperación de datos más rápida.
Firmware	Un programa informático crítico integrado en un dispositivo para controlar sus funciones de hardware específicas, como el inicio del sistema y la interacción con un enrutador.
Servidor de protocolo de transferencia de archivos (FTP)	Un servidor que traslada archivos de una computadora a otra. El protocolo de transferencia de archivos también se refiere al uso de un servidor para conectar una computadora a otra y compartir datos de forma segura.
Servidor de juegos	Un servidor que aloja juegos en línea multijugador. Las grandes redes de juegos emplean servidores para conectar a usuarios de todo el mundo.
Firmware de alto nivel	Firmware utilizado con chips de memoria flash para actualización; generalmente, tiene instrucciones más complejas que el firmware

Glosario

Término	Definición
	de bajo nivel.
Jailbreaking	Un método utilizado para obtener acceso al sistema operativo subyacente de un iPhone.
Kernel	Software que gestiona los componentes esenciales del sistema operativo, como la gestión de controladores de memoria y dispositivos y los procesos de programación, y asegura la coordinación adecuada entre el hardware y el software.
Firmware de bajo nivel	Firmware almacenado en un chip de memoria no volátil, como la memoria de solo lectura (ROM). Proporciona el control más básico para el hardware de un dispositivo, normalmente gestionando los procesos de inicio inicial del hardware.
Servidor de correo	Un servidor que almacena y entrega correo a los clientes a través de plataformas de servicio de correo electrónico.
Sistema operativo móvil	Un sistema operativo desarrollado específicamente para funcionar en un dispositivo móvil. Algunos ejemplos bien conocidos son iOS y Android.
Servidor de monitoreo y gestión	Un servidor diseñado para registrar y rastrear transacciones digitales y recibir solicitudes de usuarios.
Sistema operativo (SO)	Un tipo de software que administra todas las aplicaciones, programas y recursos de hardware de una computadora y proporciona una interfaz de usuario para interactuar con la computadora.
Seguridad del SO	Proceso de garantizar la confidencialidad, integridad y disponibilidad del SO. Implica proteger el sistema operativo de amenazas, como virus, gusanos, malware e intrusiones remotas de hackers.
Gestión de parches	Proceso para mantener las computadoras y las redes seguras, confiables y actualizadas con las características y funcionalidades necesarias.
Servidor de impresión	Un servidor que se conecta remotamente a computadoras locales para imprimir a través de una red. Con estos servidores, las organizaciones pueden usar una sola impresora para dar servicio a todo un departamento.
Servidor proxy	Un servidor que intercepta los datos enviados por un sitio web para luego enviarlos a la dirección IP de una computadora.
Rooting	Un método utilizado para obtener acceso al sistema operativo

Glosario

Término	Definición
	subyacente de un dispositivo Android.
Rootkit	Malware diseñado para ocultar su presencia y actividades al usuario y a los mecanismos de seguridad del sistema operativo.
Servidores	Un dispositivo o sistema de software especializado que almacena y procesa datos y actúa como un centro en una red, proporcionando estos datos a otros dispositivos en la red.
SO de servidor	Un sistema operativo desarrollado específicamente para gestionar y ejecutar un servidor. Algunos ejemplos de sistemas operativos de servidor ampliamente utilizados incluyen Red Hat Enterprise Linux Server y Windows Server.
Software	Un conjunto de instrucciones y datos que le indican a una computadora cómo realizar tareas específicas. Incluye programas y aplicaciones que ayudan a los usuarios a realizar diversas actividades, como navegar por Internet, escribir documentos o jugar.
Firmware del subsistema (firmware del dispositivo)	Firmware especializado que funciona independientemente del firmware del sistema principal. Por ejemplo, una impresora funciona con su propio firmware, pero el firmware también está integrado en el chip del cartucho de tinta para gestionar la comunicación con la impresora sobre los niveles de tinta.
Endurecimiento del sistema	El proceso de asegurar un sistema informático o servidor mitigando posibles vulnerabilidades.
Servidor web	Un servidor que accede a la World Wide Web a través de software de dominio público. Conecta la información almacenada de un sitio web de Internet a la computadora del usuario.
SO de estación de trabajo	Un sistema operativo desarrollado específicamente para ejecutarse en computadoras de escritorio o portátiles. Windows, macOS y Linux son algunos de los sistemas operativos más conocidos para estaciones de trabajo.

Preguntas que tengo

Glosario

Glosario

Mis notas

Glosario

Módulo 6: Seguridad de la red

Plazo	Definición
Esquemas de control de acceso	Modelos para proporcionar coherencia en el control de acceso a los recursos de red.
Advanced Encryption Standard (AES)	Un tipo de cifrado de enrutador utilizado para proteger información clasificada. Los enrutadores fabricados después de 2006 deberían tener la opción de habilitar AES junto con WPA2.
Air gap	Una técnica para el diseño seguro de redes que aísla completamente un componente de dispositivo digital o una red privada de otros dispositivos y redes. Los air gaps protegen con frecuencia los sistemas que necesitan una seguridad muy alta, como los relacionados con el ejército, los servicios públicos o las prácticas médicas.
Esquema de control de acceso basado en atributos (ABAC)	Un modelo de control de acceso en el que las decisiones se basan en atributos que definen el usuario, el recurso y el entorno donde los usuarios solicitan acceso.
Bluesnarfing	Un ataque que aprovecha las vulnerabilidades de Bluetooth para robar información o usar el dispositivo.
Ataque de desbordamiento de búfer	Un ataque en el que un programa intenta almacenar más datos en un área de almacenamiento temporal, llamada búfer, de los que puede manejar. El desbordamiento deja al programa vulnerable a más ataques, incluido el código que bloquea el sistema, daña los datos o le da al atacante el control del sistema.
Ataques de denegación del servicio (DoS)	Ataque que interrumpe el funcionamiento normal de un dispositivo para que los usuarios normales no puedan acceder a él. Los ataques DoS suelen funcionar inundando una máquina objetivo con peticiones hasta que el tráfico normal no puede procesarse.
Esquema de control de acceso discrecional (DAC)	Un modelo de control de acceso en el que cada objeto o recurso del sistema tiene un propietario que determina qué usuarios pueden acceder a él.
Ataques de denegación	Un ataque que implica que varios dispositivos conectados en línea saturan un sitio web objetivo con tráfico falso.

Glosario

Plazo	Definición
distribuida del servicio (DDoS)	
DMZ	Una red independiente que protege y agrega una capa adicional de seguridad a la red de área local (LAN) interna de una organización frente al tráfico no confiable.
Envenenamiento del sistema de nombres de dominio (DNS)	Un tipo de suplantación de identidad en el que el atacante ingresa información falsa en la caché de un servidor de nombres de dominio. El resultado es que los usuarios que buscan un sitio web específico son enviados a uno de los elegidos por el atacante.
Ataque de gemelo malvado	Ataque en el que actores maliciosos configuran una fuente wifi falsa para robar información o infiltrarse aún más en un dispositivo conectado. Los atacantes suelen emplear esta estrategia en entornos públicos, como aeropuertos, cafeterías o grandes parques públicos, donde la gente suele buscar wifi de libre acceso.
Extranet	Una red privada abierta a usuarios externos, como socios comerciales, proveedores y clientes clave. Una extranet puede ser útil para funciones que involucran a usuarios externos o al público, como pedidos en línea, seguimiento electrónico de pedidos y administración de inventario.
Controles del sistema de archivos	Un método de control de acceso en el que los controles determinan qué cuentas, usuarios, grupos o servicios pueden realizar acciones, como leer, escribir y ejecutar archivos.
Firewall	El guardián de una red filtra el tráfico, impide que personas externas obtengan acceso no autorizado y bloquea el software malicioso.
Módulo de seguridad por hardware (HSM)	Un procesador criptográfico dedicado que está diseñado específicamente para proteger el ciclo de vida de la clave criptográfica. Las empresas utilizan un HSM para proteger transacciones, identidades y aplicaciones.
Honeypot	Un sistema que atrae a los atacantes actuando como una red llena de recursos valiosos, pero que también contiene herramientas para monitorear y realizar funciones de seguridad. Por ejemplo, el sistema honeypot de un banco podría imitar una página de inicio de sesión falsa o una sección del sitio web del banco para atraer a los atacantes y recopilar información sobre sus tácticas. Luego, el banco puede usar esta información para capacitar a sus empleados sobre cómo detectar y prevenir ataques similares y mejorar las

Glosario

Plazo	Definición
	defensas de seguridad.
Intranet	Una red privada para distribuir comunicaciones exclusivamente a los usuarios internos de la organización.
Suplantación de IP	Un tipo de suplantación de identidad que implica hacerse pasar por otro sistema informático mediante la creación de paquetes IP con direcciones IP de origen falsas. Este ataque permite a los ciberdelincuentes participar en actividades maliciosas, como infectar un dispositivo con malware, robar datos o bloquear un servidor sin ser detectados.
Jamming	Un ataque en el que los nodos maliciosos interfieren intencionalmente con las redes inalámbricas para evitar la comunicación legítima. Un método común de interferencia utiliza un dispositivo que emite energía electromagnética que inutiliza la red al enviar señales y aumentar el ruido.
Balanceador de carga	Un dispositivo de hardware dedicado o un servidor orientado a Internet que ejecuta un servicio de equilibrio de carga, distribuyendo el tráfico entre varios servidores y descifrando el tráfico del sitio web. El equilibrio de carga en la nube se está convirtiendo rápidamente en la forma más popular.
Ataques de intermediario	Un ataque en el que un atacante irrumpe en una conversación existente o transferencia de datos entre dos participantes y finge ser un participante legítimo.
Suplantación de identidad de control de acceso a medios (MAC)	Un tipo de suplantación de identidad en el que alguien o algo intercepta o manipula los mensajes de control intercambiados entre un dispositivo en red y su dirección única de control de acceso a medios (MAC). Los atacantes pueden emplear muchos métodos para hacerlo, como manipular los mensajes enviados desde puntos de acceso legítimos o capturar y manipular paquetes que contienen datos de respuesta antes de que lleguen a su destino.
Esquema de control de acceso obligatorio (MAC)	Un modelo de control de acceso en el que los usuarios no tienen control sobre sus propios derechos de acceso.
Control de acceso a la red	Un proceso para controlar y gestionar el acceso a una red mediante la autenticación de usuarios y dispositivos antes de permitirles

Glosario

Plazo	Definición
(NAC)	conectarse.
Traducción de direcciones de red (NAT)	Un proceso mediante el cual una dirección IP única puede representar varias computadoras. Un dispositivo de red, a menudo un enrutador o firewall NAT, asigna esta única dirección IP pública a una computadora o grupo de computadoras dentro de una red privada.
Arquitectura de red	El diseño estructural y lógico de una red. Describe los dispositivos de red utilizados, cómo están conectados y las reglas que rigen la transferencia de datos entre ellos.
Diseño de red	Proceso de creación de arquitectura de red para una organización y situación específicas. Incluye análisis de red, selección de hardware y planificación de la implementación, entre otros procesos de planificación.
Dispositivos de infraestructura de red	Componentes de una red que controlan las comunicaciones necesarias para datos, aplicaciones, servicios y multimedia. Estos dispositivos incluyen enrutadores, firewalls, conmutadores, servidores, balanceadores de carga, sistemas de detección de intrusiones, sistemas de nombres de dominio y redes de área de almacenamiento.
Seguridad de la red	Despliegue y monitoreo de soluciones de ciberseguridad para proteger los sistemas de TI de una organización contra ataques y filtraciones.
Segmentación de red	Técnica para el diseño seguro de redes que divide una red más grande en segmentos más pequeños, también llamados subredes, generalmente a través de conmutadores y enrutadores.
Conmutador de red	Un dispositivo que integra todos los dispositivos de una red, lo que permite compartir y transferir datos sin problemas entre ellos. Los dispositivos de red conectados pueden incluir todo, desde firewalls y puntos de acceso inalámbricos hasta teléfonos, impresoras, servidores, entre otros, de protocolo de voz sobre Internet (VoIP).
Servidor proxy (proxy)	Un sistema o enrutador que proporciona una puerta de enlace entre los usuarios e Internet. Cuando los usuarios envían solicitudes en línea, la solicitud viaja a través del servidor proxy. El servidor proxy obtiene la respuesta del servidor web y luego reenvía los datos al navegador del usuario.
Punto de acceso no autorizado	Un punto de acceso inalámbrico que no pertenece a la red. Un atacante puede utilizar puntos de acceso inalámbrico no

Glosario

Plazo	Definición
	autorizados para diversos fines, como filtrar información confidencial de una empresa.
Esquema de control de acceso basado en roles (RBAC)	Un modelo de control de acceso en el que las decisiones de control de acceso se basan en los roles asignados a usuarios o grupos.
Enrutador	Conexión de hardware de una red a datos externos, generalmente desde Internet. Esos datos viajan desde un módem a un enrutador, que luego dirige los datos externos a los dispositivos de red.
Suplantación de identidad	Un ataque en el que un atacante emplea un dispositivo o una red para engañar a otras redes informáticas para que crean que son una entidad legítima. Este engaño les permite apoderarse de los dispositivos para emplearlos en ataques u obtener acceso a datos confidenciales.
Wi-Fi Protected Access (WPA)	Un tipo de cifrado de enrutador que codifica la clave de cifrado y es más seguro que WEP.
Wi-Fi Protected Access 2 (WPA2)	Un tipo de cifrado de enrutador que codifica la clave de cifrado y no permite el uso de un protocolo menos seguro.
Wired Equivalent Privacy (WEP)	Un tipo de cifrado de enrutador que utiliza ondas de radio y la misma clave de cifrado para cada paquete de datos.
Ataque de día cero	Un ataque en el que el atacante explota una vulnerabilidad de software desconocida para el creador del software antes de que este pueda lanzar un parche para solucionarla.

Preguntas que tengo

Glosario

Mis notas

Glosario

Módulo 7: Computación en la nube y virtualización

Plazo	Definición
Nube como servicio (CaaS)	Recursos de aplicaciones e infraestructura que residen en Internet.
Base de datos como servicio (DBaaS)	Un servicio de computación en la nube que proporciona a los usuarios acceso a un sistema de base de datos totalmente gestionado a través de un CSP. Con DBaaS, los usuarios pueden acceder a una base de datos sin necesidad de configurar hardware físico, instalar software o configurar su rendimiento.
Virtualización de red externa	Tipo de virtualización que ayuda a los proveedores de servicios a crear redes de área local (VLAN) virtuales agrupando sistemas físicos que están conectados a la misma LAN o dividiendo LAN separadas en la misma VLAN. Por ejemplo, un proveedor puede usar la virtualización de red externa para crear VLAN separadas para diferentes grupos o clientes. Cada grupo tendría sus propias políticas de seguridad y configuraciones de red.
Nube híbrida	Un modelo de despliegue en la nube en el que una empresa utiliza infraestructura de nube pública y privada para el almacenamiento y procesamiento de datos.
Hipervisor	Un software único que permite que una sola computadora física ejecute múltiples máquinas virtuales.
Infraestructura como servicio (IaaS)	Un servicio de computación en la nube que le permite alquilar recursos de hardware virtualizados del proveedor de servicios en la nube (CSP). Algunos ejemplos de estos recursos incluyen servidores, almacenamiento y componentes de red.
Virtualización de red interna	Un tipo de virtualización que crea una red simulada dentro de un único servidor para que el servidor sea más eficiente. La virtualización interna ofrece muchos beneficios, como usar menos hardware, ser más flexible y cambiar los recursos de red para satisfacer diferentes necesidades.
Network Functions Virtualization (NFV)	Una tecnología que virtualiza los servicios de red, como enrutadores, firewalls y balanceadores de carga, empaquetándolos como máquinas virtuales o contenedores en servidores estándar.
Tarjeta de interfaz de red (NIC)	Un componente de hardware que conecta una computadora u otro dispositivo electrónico a una red.

Glosario

Plazo	Definición
Virtualización de redes	Un tipo de virtualización que combina hardware, recursos de software y funcionalidad de red en un único sistema basado en software.
Plataforma como servicio (PaaS)	Un servicio de computación en la nube que permite a los desarrolladores crear, desplegar y gestionar aplicaciones sin preocuparse de la base técnica. Los desarrolladores pueden centrarse en crear aplicaciones en lugar de gestionar servidores, bases de datos y otros componentes de la infraestructura.
Nube privada	Un modelo de despliegue en la nube en el que una empresa tiene su propia infraestructura informática en la nube y no se comparte con nadie más.
Nube pública	Un modelo de despliegue en la nube en el que un proveedor de servicios en la nube (PSC) da a los usuarios acceso a sistemas, servicios y datos virtuales a través de Internet.
Software como servicio (SaaS)	Un servicio de computación en la nube que ofrece aplicaciones a través de Internet. Algunos ejemplos de aplicaciones SaaS son el correo electrónico, la gestión de documentos y el software de gestión de relaciones con los clientes (CRM).
Dispositivo virtual	Un software preinstalado en una o más máquinas virtuales que cumple una función específica.
Host virtual	Una plataforma de alojamiento que proporciona recursos informáticos y de almacenamiento a uno o varios sitios web, aplicaciones o servicios, cada uno con un nombre de dominio y una dirección IP únicos.
Virtualización	Un proceso mediante el cual una sola máquina física puede ejecutar múltiples sistemas operativos.
Tarjeta de interfaz de red virtual (VNIC)	Un componente de hardware que conecta una computadora u otro dispositivo electrónico a una red en un entorno virtualizado.
Software de VMware	Software que permite crear y gestionar versiones virtuales de funciones informáticas. Está dirigido a usuarios domésticos, de pequeñas empresas y de nivel empresarial.

Preguntas que tengo

Glosario

Mis notas

Glosario

Módulo 8: Protección de la infraestructura en la nube

Término	Definición
Interfaz de programación de aplicaciones (API)	Un grupo de rutinas, protocolos y herramientas para crear aplicaciones de software.
Broker de seguridad de acceso a la nube (CASB)	Una herramienta o servicio de seguridad que actúa como un firewall para los servicios en la nube, proporcionando un portal para hacer cumplir las políticas de seguridad y garantizar que las acciones de los usuarios autorizados se adhieran a las políticas de seguridad de la empresa.
Aplicación en la nube	Un tipo de aplicación de software que se ejecuta en la infraestructura de la nube.
Seguridad de aplicaciones en la nube	Políticas, herramientas y protocolos diseñados para proteger las aplicaciones y los datos basados en la nube al garantizar la visibilidad, defenderse contra ataques cibernéticos y restringir el acceso a los usuarios autorizados.
Recuperación ante desastres en la nube	Un servicio que permite a las organizaciones replicar y recuperar sus aplicaciones y datos críticos en la nube en caso de una interrupción o desastre de TI, garantizando la continuidad del negocio y minimizando el tiempo de inactividad.
Gestión de derechos de infraestructura en la nube (CIEM)	Un conjunto de herramientas y prácticas que permiten a las organizaciones comprender sus derechos y licencias mediante el análisis y la asignación de todas las identidades, roles, grupos y políticas en varias plataformas en la nube.
Plataforma de protección de aplicaciones nativa de la nube (CNAPP)	Una solución de seguridad para proteger las aplicaciones nativas de la nube que se crea utilizando microservicios, contenedores y otras tecnologías nativas de la nube.
Gestión de la postura de seguridad en la nube (CSPM)	Un componente crítico de la seguridad de las aplicaciones en la nube que ayuda a las organizaciones a identificar y mitigar posibles riesgos de seguridad.
Prevención de pérdida de datos	Un conjunto de herramientas y procesos que ayudan a las organizaciones a proteger la información confidencial de la

Glosario

Término	Definición
(DLP)	divulgación o el uso no autorizados detectando y previniendo las filtraciones de datos en tiempo real.
Gestión de acceso a la identidad (IAM)	Una herramienta que implica administrar las identidades de los usuarios y controlar su acceso a aplicaciones, redes y otros recursos.
Gobernanza y administración de identidades (IGA)	Una solución que ayuda a las organizaciones a gestionar el ciclo de vida de la identidad de los usuarios y su acceso a aplicaciones y datos críticos.
Microservicios	Un tipo de arquitectura utilizado en aplicaciones en la nube donde un sistema de software se divide en componentes pequeños e independientes que se comunican entre sí a través de API.
Escalabilidad bajo demanda	La capacidad de un sistema o aplicación para ajustar rápida y fácilmente sus recursos informáticos para satisfacer demandas o cargas de trabajo cambiantes.
Principio del privilegio mínimo (POLP)	Un concepto de seguridad que restringe a los usuarios o procesos a solo el acceso y los permisos necesarios para realizar sus tareas.
Gestión de acceso privilegiado (PAM)	Una solución que proporciona acceso seguro y controlado a cuentas privilegiadas, como las de los administradores del sistema, para evitar el acceso no autorizado.
TI en la sombra	Uso de soluciones tecnológicas no autorizadas en una organización, a menudo fuera del ámbito del departamento de TI

Preguntas que tengo

Glosario

Glosario

Mis notas

Glosario

Módulo 9: Operaciones de seguridad

Término	Definición
Gestión del cumplimiento normativo	El enfoque sistemático que adoptan las organizaciones para garantizar que todas las aplicaciones, sistemas y herramientas y procesos de seguridad cumplan con las regulaciones de privacidad de datos. Algunos ejemplos de estas regulaciones incluyen, entre otros, el Reglamento General de Protección de Datos (RGPD) y la Ley de Portabilidad y Responsabilidad del Seguro Médico (HIPAA).
Capacitación en cumplimiento	Programas e iniciativas educativos diseñados para educar a los empleados sobre las leyes, regulaciones, estándares de la industria y políticas internas relevantes que rigen sus actividades laborales. Por ejemplo, una organización podría organizar sesiones de capacitación sobre identificación y mitigación de riesgos cibernéticos, protección de datos confidenciales y cumplimiento de los requisitos normativos.
SOC híbrido	Un modelo SOC que combina los modelos SOC interno y SOCaaS, de modo que la organización puede emplear recursos internos, incluido el personal interno, y servicios de seguridad externalizados.
Respuesta a incidentes (IR)	El conjunto de acciones que una organización toma para prepararse, exponer y detener los ciberataques.
SOC interno	Un modelo SOC en el que una organización tiene un equipo SOC interno y recursos dedicados a gestionar las operaciones de seguridad. La organización posee y mantiene la infraestructura y las herramientas necesarias para operar el SOC.
Gestión de registros	El proceso de recopilación, almacenamiento, análisis y administración de datos de registro generados por varios sistemas, aplicaciones y dispositivos de red dentro de una organización.
Formación inicial	El proceso de educar a los empleados o contratistas recién contratados sobre los principios, prácticas, políticas y procedimientos esenciales de ciberseguridad específicos de sus funciones dentro de una organización.
Capacitación sobre phishing	Programas educativos diseñados para enseñar a las personas a reconocer, evitar y responder a los ataques de phishing.
Post mortem y refinamiento (revisión posterior al	Un análisis estructurado realizado luego de un incidente o violación de seguridad. El refinamiento en ciberseguridad se refiere al proceso de implementación de mejoras y ajustes basados en los hallazgos y

Glosario

Término	Definición
incidente)	recomendaciones de evaluaciones de seguridad post-mortem o en curso.
Recuperación y corrección	Procesos críticos que siguen a la respuesta a incidentes y tienen como objetivo restaurar las operaciones normales, mitigar los daños y prevenir futuras ocurrencias.
Capacitación recurrente	Programas e iniciativas educativos continuos que brindan actualizaciones periódicas, repasos y nueva información a los empleados y partes interesadas sobre las amenazas de ciberseguridad, las mejores prácticas y los requisitos de cumplimiento.
Centro de operaciones de seguridad (SOC)	Un equipo dedicado de profesionales de ciberseguridad que utiliza software especializado para monitorear, detectar, investigar y responder activamente a las posibles amenazas e incidentes de seguridad de una organización en tiempo real.
SOC como servicio (SOCaaS)	Un modelo SOC en el que una organización subcontrata casi todas sus operaciones de seguridad a un proveedor externo. A su vez, el tercero proporciona el personal y la tecnología necesarios para monitorear, analizar y responder a los incidentes.
Instalaciones del SOC	Una ubicación física centralizada donde los profesionales de ciberseguridad monitorean, detectan, analizan y responden a incidentes y amenazas de seguridad.
Software del SOC	Un tipo de software de seguridad que los equipos del SOC utilizan para monitorear, analizar y responder a las amenazas de seguridad en tiempo real.
Equipo del SOC	Un grupo de profesionales de ciberseguridad responsables de monitorear y analizar la postura de seguridad de una organización.
Detección de amenazas	El proceso de identificar posibles amenazas de seguridad y actividades maliciosas dentro del entorno de TI de una organización.
SOC virtual (V-SOC)	Un modelo de SOC basado en la nube en el que una organización construye, aloja y mantiene su infraestructura y herramientas de seguridad en la nube, y el equipo interno de SOC de la organización trabaja a distancia.

Preguntas que tengo

Glosario

Mis notas

Glosario

Módulo 10: Supervisión de la seguridad

Término	Definición
Soluciones de monitoreo activo	Herramientas de software que funcionan en segundo plano y buscan activamente posibles problemas o ralentizaciones. Este tipo de soluciones alertan a los administradores de red tan pronto como se alcanzan anomalías o umbrales predefinidos, lo que permite una respuesta y resolución rápidas.
Agente	Una aplicación de software instalada en un punto final que recopila, procesa e informa datos relacionados con el estado de seguridad del dispositivo.
Análisis de comportamiento	La práctica de recopilar y analizar datos sobre las actividades de los usuarios, el tráfico de red y los eventos del sistema para comprender los patrones de comportamiento. Este análisis ayuda a identificar desviaciones del comportamiento normal que pueden indicar incidentes de seguridad, fraude u otros riesgos.
Gestión de puntos finales	El proceso de monitorear, proteger y controlar dispositivos conectados a una red. Esto implica implementar políticas de seguridad, actualizar el software, monitorear el estado del dispositivo y garantizar el cumplimiento para proteger la red de las vulnerabilidades asociadas con los endpoints.
Endpoints	Dispositivos como computadoras, teléfonos inteligentes, tabletas y dispositivos IoT que se conectan a una red. Estos dispositivos actúan como puntos de entrada para la comunicación y la interacción dentro de la red, lo que los hace fundamentales para la seguridad y la gestión de la red.
Reconocimiento de la red	El proceso de recopilar información de forma activa o pasiva sobre una red informática, sus dispositivos y sus servicios para identificar posibles vulnerabilidades.
Plan de respuesta a incidentes	Un conjunto predefinido de procedimientos y acciones que siguen los equipos de seguridad cuando se detecta un incidente de seguridad. El plan describe los pasos para identificar, contener, erradicar y recuperar de las amenazas para minimizar los daños y restablecer las operaciones normales.
nslookup	Una herramienta de línea de comandos que obtiene información sobre un sistema host: ayuda a diagnosticar y solucionar problemas relacionados con DNS mediante la recuperación de detalles como la dirección IP de un dominio o el dominio asociado con una dirección IP.

Glosario

Término	Definición
	Un ejemplo es ejecutar el comando "ping", como "ping google.com", para verificar la conectividad y medir el tiempo de ida y vuelta a los servidores de Google.
Analizador de paquetes	Una herramienta que captura y analiza datos en tránsito a través de una red. Por ejemplo, Wireshark es un analizador de protocolos de red que te permite capturar y examinar interactivamente el tráfico que se ejecuta en una red informática.
Soluciones de monitoreo pasivo	Herramientas de software que observan y registran las actividades de la red sin interactuar activamente con el tráfico. Estas soluciones proporcionan a los administradores registros detallados y datos históricos, lo que les permite analizar el comportamiento de la red, el rendimiento y las tendencias de seguridad sin afectar el funcionamiento del sistema.
Prueba de ping	Una herramienta de diagnóstico que mide el tiempo que tarda un paquete de datos, o ping, en viajar de una computadora o servidor a otro. Prueba la accesibilidad de un host y evalúa la latencia, que es crucial para determinar el rendimiento de la red y detectar posibles problemas de conectividad.
Información de seguridad y gestión de eventos (SIEM)	Una solución de seguridad que permite a las organizaciones reconocer y abordar posibles amenazas y vulnerabilidades de seguridad antes de que tengan la oportunidad de interrumpir las operaciones comerciales.
Postura de seguridad	El estado general de seguridad de una organización, que refleja su capacidad para protegerse y responder a las amenazas de ciberseguridad. Esto incluye la eficacia de los controles, políticas y procedimientos de seguridad y la preparación de la organización para gestionar y mitigar los riesgos.
Traceroute	Una herramienta de diagnóstico que interactúa activamente con una red informática para encontrar problemas con una conexión a Internet.
Análisis del comportamiento de usuarios y entidades (UEBA)	Un enfoque de ciberseguridad que se centra en monitorear y analizar el comportamiento de los usuarios y entidades dentro de una red para detectar actividades inusuales o potencialmente maliciosas.

Glosario

Preguntas que tengo

Mis notas

Glosario

Módulo 11: Respuesta a incidentes

Término	Definición
Superficie de ataque	Un análisis de todas las vulnerabilidades y puntos de entrada potenciales a través de los cuales un usuario no autorizado puede intentar acceder a un sistema, red o aplicación, para afectar o extraer datos del sistema.
Contención	El proceso de evitar que un ataque continúe y cause más daños o inhabilitación al sistema.
Marco Cyber Kill Chain	Una herramienta para el análisis de intrusiones que proporciona una estructura para identificar, comprender, aislar y responder a comportamientos maliciosos.
Erradicación	El proceso de eliminar una amenaza de todos los dispositivos afectados, como volver a crear una imagen de los dispositivos, deshabilitar los servicios y actualizar el software.
Impacto funcional	El grado en que un ataque afectará la eficacia de un sistema y la capacidad de los usuarios para acceder a lo que necesitan.
Marco de respuesta a incidentes	Un enfoque estructurado para manejar y gestionar incidentes de seguridad, que describe los procesos y procedimientos para identificar, investigar y responder a las amenazas de ciberseguridad.
Respuesta a incidentes (IR)	El conjunto de acciones que realiza una organización para prepararse, exponer y detener los ciberataques.
Plan de respuesta a incidentes (PRI)	Documentación que detalla las acciones necesarias en caso de ciberataque, el orden en el que deben realizar y los miembros del equipo que deben llevarlas a cabo.
Indicador	Un indicio de que un incidente podría ocurrir o está sucediendo ahora, como una alerta de un programa antimalware que indica que un troyano ha infectado un dispositivo.
Impacto informativo	La medida en que un ataque afectará la información en un sistema, incluida la información que podría ser robada o destruida y una medición de las posibles consecuencias.
Análisis de intrusiones	El proceso de emplear información sobre un ataque para determinar su alcance, el método utilizado por el atacante para obtener acceso y el alcance del daño al sistema o la red.
Marco MITRE ATT&CK	Una matriz detallada que clasifica las tácticas y técnicas que emplean los atacantes para llevar a cabo ciberataques. Significa <i>tácticas adversas, técnicas y conocimiento común</i> .
Precursor	Una señal o indicación de que un ataque o incidente de

Glosario

Término	Definición
	seguridad podría ocurrir en el futuro.
Impacto de la recuperabilidad	La extensión del daño que causa un ataque y el tiempo que la organización podría necesitar para restaurar el sistema y la información a su estado anterior.
Recuperación	El proceso de restaurar y devolver los sistemas, datos y operaciones afectados a la normalidad después de un incidente o violación de seguridad.

Preguntas que tengo

Mis notas

Glosario

Módulo 12: Análisis forense de sistemas digitales

Término	Definición
Herramientas de adquisición y análisis	Herramientas que recopilan y analizan pruebas digitales de fuentes de datos, como unidades de disco duro y tarjetas de memoria.
Análisis	La tercera fase de la investigación forense digital cuando los investigadores analizan los datos relevantes de la fase de examen para sacar conclusiones significativas al respecto.
Autopsia	Una herramienta de recuperación de datos de código abierto que se utiliza para analizar y recuperar datos de medios de almacenamiento en sistemas operativos Windows, Linux y macOS.
Cadena de custodia	Un proceso utilizado en investigaciones forenses para registrar la historia cronológica de la evidencia. Realiza un seguimiento de la posesión, manejo y transferencia de pruebas desde el momento en que alguien las recoge hasta su presentación en la corte, asegurando su integridad y admisibilidad.
Recopilación	La primera fase de una investigación forense digital cuando los investigadores identifican y recopilan posibles fuentes de evidencia. Esta fase implica etiquetar, documentar y recopilar datos de varios dispositivos digitales, garantizando al mismo tiempo la integridad y autenticidad de la evidencia.
Interfaz de línea de comandos (CLI)	Una interfaz de usuario en la que los usuarios escriben comandos para navegar y administrar el sistema.
Tallado de datos	El proceso de extraer datos de un dispositivo de almacenamiento sin depender del sistema de archivos o los metadatos. Este proceso es especialmente valioso para recuperar evidencia digital de dispositivos de almacenamiento dañados o reformateados donde

Glosario

Término	Definición
	el análisis tradicional del sistema de archivos no es práctico. Implica extraer datos directamente del dispositivo de almacenamiento mediante la identificación de firmas de archivos o patrones específicos en los datos sin procesar, sin tener que depender del sistema de archivos o de los metadatos.
Preservación de datos	El proceso de proteger y salvaguardar los datos electrónicos para mantener su integridad, autenticidad y usabilidad con fines de investigación.
Recuperación de datos	Un proceso para recuperar datos perdidos, eliminados, dañados o inaccesibles de otro modo.
Herramientas de ciencia forense digital	Hardware o software que recoge, extrae, clasifica, conserva o recupera pruebas digitales.
Ciencia forense digital	La aplicación de la ciencia a la identificación, recopilación, examen y análisis de datos, preservando la integridad de la información y manteniendo una estricta cadena de custodia de los datos.
Examen	La segunda fase de una investigación forense digital, cuando los investigadores examinan los datos recopilados para determinar lo relevante y extraerlo para su posterior análisis.
FTK Imager	Una herramienta de adquisición y análisis de código abierto para crear imágenes de disco sin modificar ni realizar ningún cambio en los datos originales, garantizando la solidez forense y preservando las pruebas con fines de investigación.
Valor hash	Una serie de números, generados mediante un algoritmo matemático, que identifica de forma única un dato. Sirve como una huella digital, identificando de forma única los datos de una manera que facilita la detección de cualquier alteración o manipulación.
Imagen	Una copia bit a bit de un dispositivo de almacenamiento, como una unidad de disco duro o una unidad flash USB, incluido todo su contenido y estructura.
Herramientas de imagen	Herramientas que crean réplicas exactas de medios de almacenamiento, como unidades de disco duro, unidades flash USB, tarjetas de memoria u otros medios de almacenamiento. Permiten a los investigadores trabajar con copias de los datos sin alterar ni comprometer la fuente original, manteniendo así su solidez forense.
Kali Linux	Una distribución de Linux centrada en la ciberseguridad con una

Glosario

Término	Definición
	variedad de herramientas estándar de ciberseguridad, que incluyen Autopsy, utilidades de tallado de datos y otras aplicaciones forenses digitales.
Paquete	Pequeño fragmento de datos en tránsito por una red. Contiene tanto la carga útil, que lleva la información real que se envía, como la información de cabecera, que incluye detalles como las direcciones de origen y destino y otra información necesaria para el encaminamiento y la entrega.
Resolución de problemas	El uso de la lógica y la razón para resolver un problema. Implica emplear el pensamiento creativo, el conocimiento, la intuición y la experiencia para desarrollar soluciones que satisfagan mejor las necesidades de la persona o la organización.
Datos brutos	Información sin procesar y sin analizar que los investigadores han recopilado durante una investigación forense digital.
Herramientas de recuperación	Herramientas que recuperan archivos borrados o inaccesibles, como archivos almacenados en imágenes dañadas o dañadas.
Herramientas de triaje	Herramientas que escanean rápidamente grandes cantidades de datos adquiridos en busca de archivos o palabras clave importantes. Priorizan la extracción de datos potencialmente relevantes en función de criterios predefinidos, como tipos de archivos, metadatos o palabras clave.
Máquina virtual (VM)	Una versión basada en software de un sistema informático físico que opera dentro de otro entorno informático. Las máquinas virtuales pueden ejecutar sus propias aplicaciones y otro software, al igual que las máquinas físicas.
Datos volátiles	Información temporal almacenada en la memoria del dispositivo, como procesos en ejecución, archivos abiertos y conexiones de red, que se pierde cuando se apaga el sistema o finaliza la sesión.
Volatilidad	Una herramienta de adquisición y análisis que puede extraer datos volátiles de la RAM, como datos del sistema operativo y procesos que se ejecutan en la memoria.
Bloqueador de escritura	Un dispositivo que bloquea cualquier comando de escritura enviado a un dispositivo de almacenamiento, como una unidad de disco duro o una unidad flash USB. Al interceptar y bloquear las solicitudes de escritura, los bloqueadores de escritura garantizan que la integridad de la evidencia original se conserve durante el proceso de examen forense.

Glosario

Preguntas que tengo

Mis notas

Glosario

Módulo 13: Amenazas emergentes y futuro de las tecnologías de ciberseguridad

Término	Definición
5G	La quinta generación de redes celulares, que permite velocidades más rápidas debido a la latencia ultra baja y aumenta la cobertura de la red.
Inteligencia artificial	Tecnología que permite a las computadoras y máquinas simular la inteligencia humana y las capacidades de resolución de problemas. Los profesionales de la ciberseguridad emplean la IA para diversas tareas, como la creación de modelos predictivos que alertan a las organizaciones de posibles amenazas antes de que se produzca un ataque.
Biotecnología	Utilización de organismos vivos o de sus componentes para crear productos útiles o resolver problemas. La biotecnología puede emplear en diversos campos para desarrollar nuevos tratamientos, mejorar el rendimiento de las cosechas, crear vacunas y encontrar soluciones innovadoras a los retos a los que se enfrentan las personas.
Sistema de nombres de dominio (DNS)	Una parte fundamental de la infraestructura de Internet que traduce nombres de dominio (como ejemplo.com) en sus direcciones IP correspondientes (como 192.0.2.1).
Tecnología emergente	Cualquier producto o servicio innovador que aún se encuentre en las primeras etapas de desarrollo, prueba o adopción.
IA generativa	Un subconjunto de la IA que se enfoca en crear o generar texto, imágenes y otro contenido de alta calidad basado en datos en los que se entrena el modelo de IA. Algunos ejemplos conocidos de IA generativa incluyen chatbots y ChatGPT de OpenAI.
Genómica	La rama de la biología molecular que estudia la estructura, función, evolución y mapeo de genomas, que es el conjunto completo de ADN, incluidos todos los genes de un organismo.
Internet de las cosas (IoT)	Una red de dispositivos físicos, vehículos, electrodomésticos y otros objetos físicos que cuentan con sensores, software y conectividad de red que les permite recopilar y compartir datos.
Nanotecnología	El campo de la ciencia y la ingeniería que estudia el diseño, la síntesis, la caracterización y la aplicación de materiales y dispositivos a nanoescala.
Computación cuántica	Una tecnología que utiliza la mecánica cuántica para resolver problemas que son demasiado complejos para que las computadoras o supercomputadoras clásicas los resuelvan o los

Glosario

Término	Definición
	solucionen con la suficiente rapidez.
Latencia ultrabaja	Un retraso extremadamente corto en la transmisión y recepción de datos, lo que permite una comunicación o respuesta casi instantánea. Ofrecer una latencia ultrabaja es uno de los avances más significativos que introducen las redes 5G.

Preguntas que tengo**Mis notas**

Glosario